

统一权限管理系统架构设计文档（V6.0）

设计说明：基于 NIST RBAC/ABAC 标准，结合金融行业 IAM 工程实践，形成可直接落地的完整架构设计。采用渐进式复杂度原则，核心表结构 14 张，支持按需扩展（信息屏障、PAM 特权管理、Merkle 防篡改、区块链存证等模块均预留接入点，无需改动核心模型）。

一、系统定位与边界

1.1 系统定位

统一权限管理系统（PMS, Permission Management System）是集团的**统一身份治理与访问控制中台**，职责边界如下：

负责：

- 员工/外包/服务账号的统一身份生命周期管理（入职、转岗、离职、冻结）
- 多应用（CRM、柜台、风控、清算、运营后台等）SSO 单点登录
- 会话管理（Redis 集中管控，支持踢人、并发控制）
- RBAC + ABAC + PBAC 三层权限模型的统一维护与决策
- 角色体系、角色继承（闭包表）、SoD 职责分离互斥规则
- 行级数据范围控制 + 列级脱敏规则
- 审计日志采集、HMAC 防篡改、合规归档
- 风险评分、异常行为检测、动态策略决策
- 多法律实体（多牌照）与多司法辖区差异化合规

不负责（由外部系统承担，按需扩展）：

- 审批工作流 → 独立通用审批流服务，PMS 通过 API 提交+回调
- 特权凭据托管 → 配置中心 / KMS
- 信息屏障、区块链存证、PAM 特权管理 → 预留扩展点，Phase 5+ 按需叠加

1.2 核心设计原则

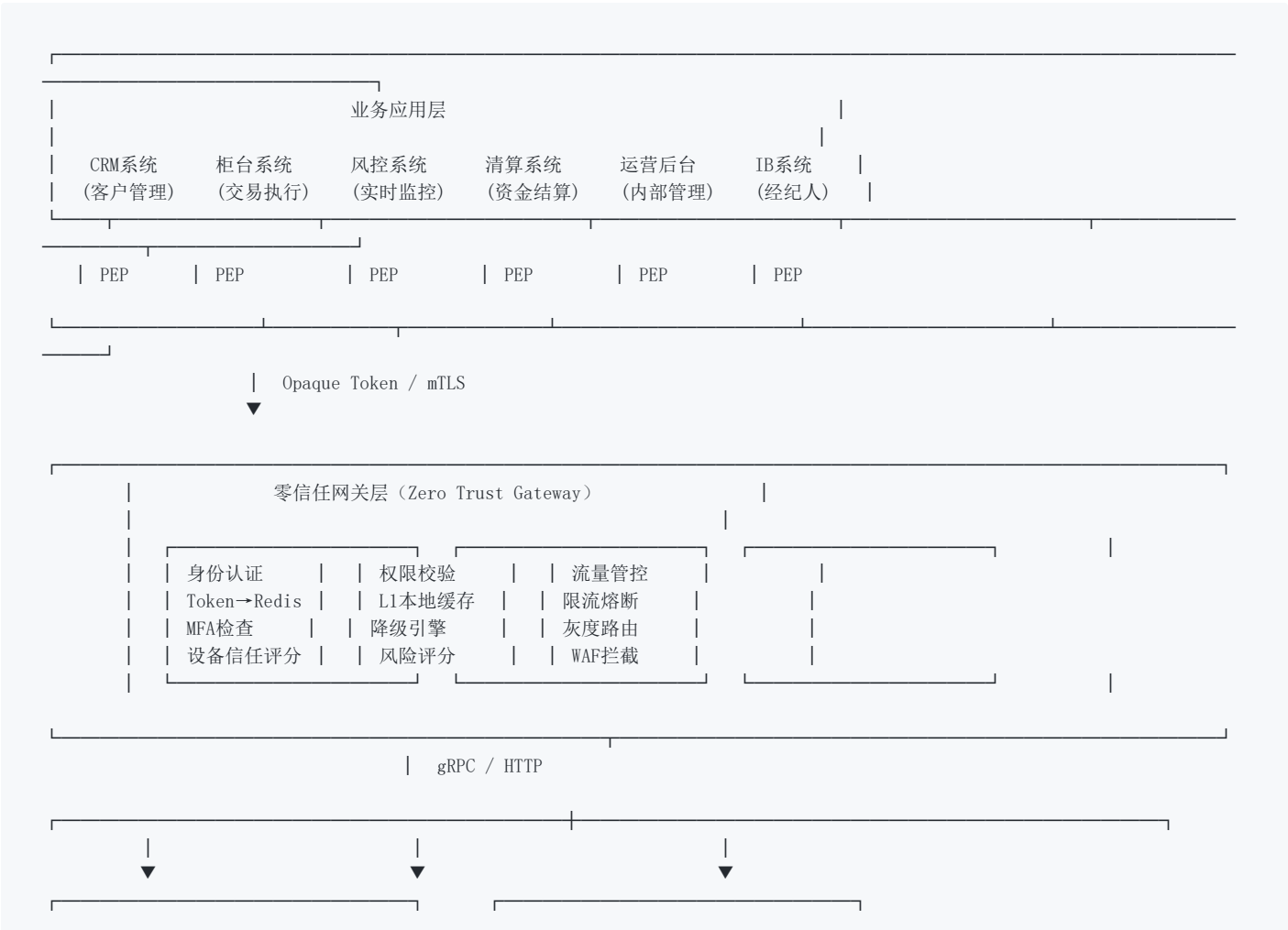
序号	原则	说明
1	Zero Trust 永不信任	所有请求无论内外网都需实时验证，不因 IP 内网而信任
2	最小权限 Least Privilege	默认拒绝，仅授予完成工作所必需的最小权限，临时权限强制过期
3	职责分离 SoD	四眼原则系统强制，交易录入≠审批、开发≠运维、管理≠审计
4	策略与内容分离	策略配置化（ABAC 策略 JSON + 管理后台维护），代码层不硬编码业务规则
5	DENY 优先 + 白名单模式	DENY 策略优先级最高、直接拦截；未显式 ALLOW 即拒绝
6	可降级	PDP 故障三级降级，高危操作降级必拒绝，宁可业务中断不可权限失控
7	合规内建	硬性合规（日志写入、离职冻结）代码层强制，不可绕过
8	审计不可篡改	HMAC 签名 + WORM 冷存储，关键审计长期不可删改
9	多租户多辖区	entity_id 贯穿全表，支持集团下多法律实体（多牌照）、多司法辖区差异化策略
10	性能优先	分层缓存（L1 Caffeine + L2 Redis + L3 DB），PDP P99 决策延迟 < 20ms
11	渐进式复杂度	先交付 RBAC，再叠加 ABAC，最后 AI 风控，避免过度设计与实施烂尾
12	可观测与可追溯	每次决策带 trace_id + decision_reason，全链路可回溯

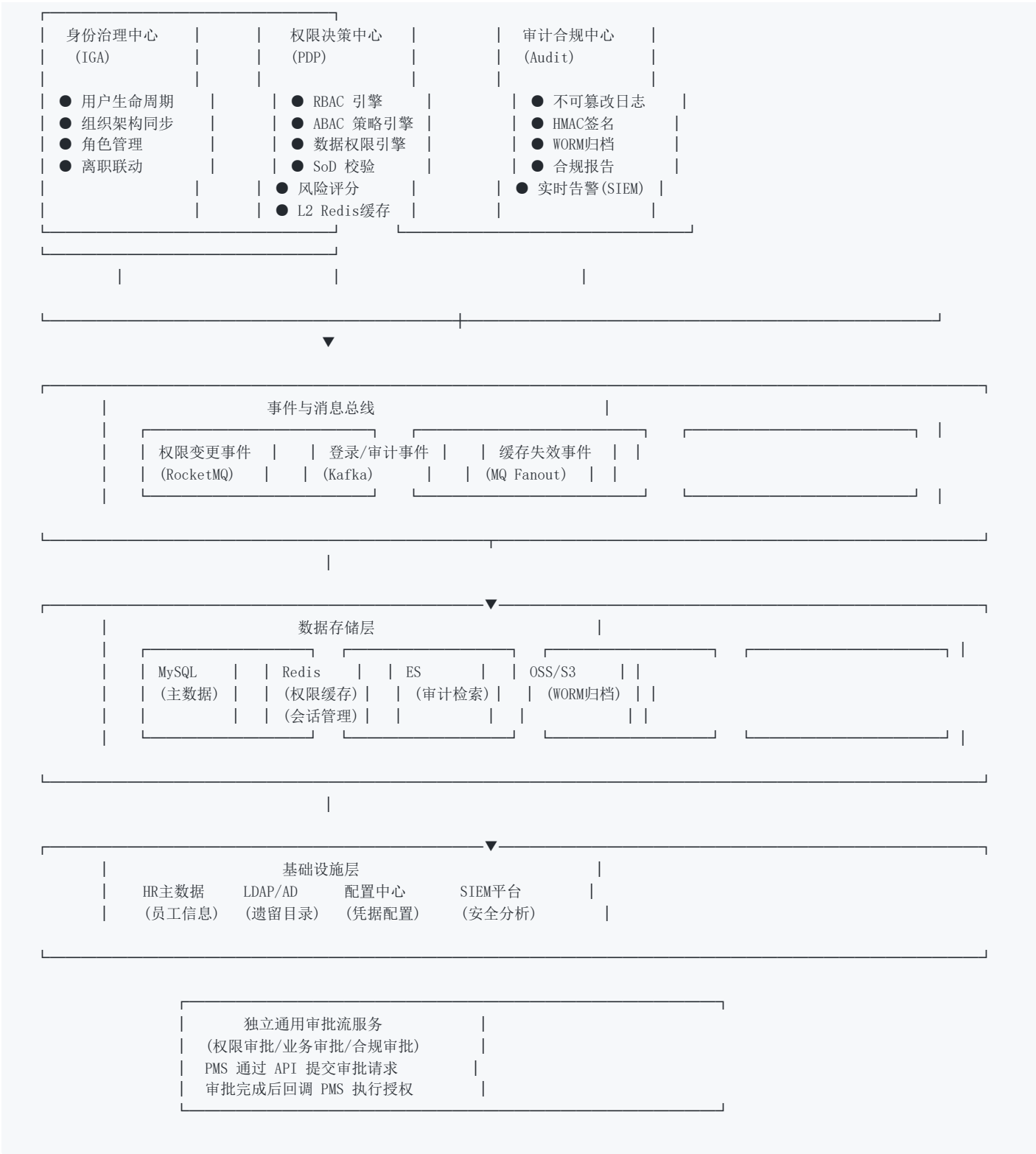
二、通用实践与落地方式

实践	本设计落地
联邦式 IAM 中台	HR 主数据 → IAM 中台 → 各业务系统 SSO
SSO + MFA	Opaque Token + Redis Session + TOTP/FIDO2
RBAC + ABAC + PBAC 三层混合	三层融合引擎，DENY 优先、ALLOW 白名单
策略即代码（Policy as Code）	结构化 JSON 策略 + 版本化 + 定时生效
SoD 职责分离	静态互斥授权前拦截，动态互斥会话激活时拦截
不可篡改审计	HMAC 单条签名 + WORM 冷存储
数据分级 + 列级脱敏	数据分级字典 + 按角色动态脱敏
三层对象模型	Subject → Grant → Permission 三表分离
多法律实体隔离	entity_id 贯穿全表
审批工作流	独立通用审批流服务，PMS 通过 API 对接

三、整体架构

3.1 逻辑架构





3.2 认证方案：Opaque Token + Redis Session

不使用 JWT，采用服务端会话：Token 仅是随机字符串，会话状态存 Redis，踢人/冻结即时生效。

```
登录 → 生成随机 Token → Redis SET token:{value} = session (TTL 8h) → 返回 Token
请求 → 网关 GET token:{value} → 未命中 401 / 命中 → 刷新 TTL + 鉴权
踢人 → DEL token:{value} (立即生效)
并发 → user_sessions:{userId} 有序集合，超限踢最早 session
```

会话数据完全存 Redis，不落 MySQL，审计日志记录登录/登出事件满足追溯。

3.3 两条控制链路

A. 在线鉴权链路（同步、低延迟）

适用于业务应用的每次 API/菜单/按钮访问鉴权。

特点：强一致、低延迟（P99 < 20ms）、高并发（峰值 50K QPS）、必须可降级。

B. 授权治理链路（异步、强合规）

适用于授权申请、审批、权限变更、SoD 扫描、僵尸权限清理。

特点：强流程、强审计、全留痕。审批环节由**独立审批流服务**承担，PMS 负责提交审批请求和接收审批结果回调。

两条链路逻辑隔离：鉴权链路独立部署，治理链路故障不影响在线鉴权。

3.4 三级降级策略

权限校验降级三级模式（PMS 故障时业务不失控）：



- 关键规则：
- 降级期间，高风险操作（出金、大额交易、敏感数据导出、权限变更）必须全部拒绝，宁可业务中断，不可权限失控
 - 降级状态由 PDP 健康检查自动判定，支持人工强制切换
 - 每级降级均触发 P0 告警，SRE 值班必须 5 分钟内响应

四、权限模型与领域字典

4.1 三层权限模型

层级	模型	决策依据	适用场景	示例
基础层	RBAC	角色-权限点绑定	菜单、按钮、API、功能点	客户经理可访问"客户列表"菜单
控制层	ABAC	主体/资源/环境属性	数据范围、时间窗口、IP 约束	只能查看 本机构 客户数据
策略层	PBAC	业务规则 + 合规策略	动态业务规则、合规条件	大额出金需 双人审批 + 交易时段

4.2 应用域字典（entity_id 所属法律实体隔离）

应用域	域代码	核心场景	敏感等级
客户管理域	CRM	客户信息、客户画像、客户经理跟进	高
交易柜台域	COUNTER	开户、交易、资金划转、大额业务	极高
风控监控域	RISK	实时监控、告警处置、风险模型	极高
清算结算域	CLEARING	资金清算、中登结算、对账	极高
合规管理域	COMPLIANCE	合规审查	极高
IB 经纪人域	IB	佣金结算、客户引荐、提现	高
运营支撑域	OPERATION	公告、活动、系统配置	中
管理后台域	ADMIN	权限管理、系统管理	极高

4.3 资源类型字典

资源类型	资源编码示例	典型鉴权场景	是否需要数据权限
MENU 菜单	crm:menu:customer_list	前端菜单展示控制	否
BUTTON 按钮	crm:button:customer_export	前端按钮可见性	否
API 接口	POST /api/crm/customers/export	网关 API 鉴权	是（行级+列级）
DATA_OBJECT 数据对象	crm:data:customer	数据域整体授权	是
FIELD 字段	crm:data:customer:id_card	字段脱敏控制	是（列级）
FUNCTION 功能	counter:func:large_withdrawal	业务功能开关	否

4.4 角色分层体系

全局角色层（跨所有系统）	
└── GLOBAL_EMPLOYEE	全员基础角色（所有正式员工默认拥有，仅含登录+站内信）
└── GLOBAL_AUDITOR	合规审计员（跨系统只读审计日志，不可修改任何业务数据）
└── GLOBAL_SYSADMIN	系统管理员（技术配置，不涉及客户/资金/交易数据）
└── GLOBAL_SUPER_ADMIN	超级管理员（仅 2-3 人，任何操作需双人审批）
向下继承（权限递增），继承深度最大 3 层	
▼	
CRM 域角色	
└── CRM_READONLY	客户数据只读（数据分析、汇报专用）
└── CRM_STAFF	客户经理（基础查看+跟进，数据范围=分配客户）
└── CRM_SENIOR	高级客户经理（+审批发起、+VIP 客户，数据范围=本团队）
└── CRM_TEAM_LEAD	团队负责人（+团队数据全量，数据范围=本团队）

└── CRM_BRANCH_MGR	营业部经理（数据范围=本营业部）
└── CRM_REGIONAL_MGR	区域总监（数据范围=本区域多个营业部）
└── CRM_ADMIN	CRM 系统管理员（配置管理，不含客户数据）
柜台域角色	
└── COUNTER_READONLY	柜台只读（内部查询、统计）
└── COUNTER_CLERK	普通柜员（开户+小额，单笔 ≤ 5 万）
└── COUNTER_SENIOR	高级柜员（大额交易，单笔 ≤ 50 万）
└── COUNTER_SUPERVISOR	柜台主管（授权审批、异常处理、单笔 ≤ 500 万）
└── COUNTER_DIRECTOR	柜台总监（大额审批，单笔 > 500 万需双人复核）
└── COUNTER_ADMIN	柜台管理员（配置）
风控域角色	
└── RISK_MONITOR	风险监控员（只读实时数据）
└── RISK_ANALYST	风控分析师（+报表导出、+模型查看）
└── RISK_MANAGER	风控经理（+阈值审批、+模型审批）
└── RISK_DIRECTOR	风控总监（+黑名单维护、+应急处置）
└── RISK_ADMIN	风控管理员（规则配置）
合规域角色	
└── COMPLIANCE_REVIEWER	合规审查员（跨系统只读）
└── COMPLIANCE_MANAGER	合规经理
└── COMPLIANCE_DIRECTOR	合规总监
临时/场景角色（强制有效期，到期自动回收）	
└── TEMP_SUBSTITUTE	临时替岗（继承指定角色权限子集，最长 30 天）
└── TEMP_EMERGENCY	应急响应（特殊时期临时授权，最长 72 小时）
└── TEMP_AUDIT_TASK	专项审计任务（特定数据集只读，任务结束自动回收）

4.5 SoD 职责分离互斥矩阵

角色 A	角色 B	互斥类型	违规处置	合规依据
COUNTER_CLERK 交易录入员	COUNTER_SUPERVISOR 交易审批员	静态互斥	直接拒绝	SOX、四眼原则
WITHDRAWAL_OPERATOR 出金操作员	WITHDRAWAL_APPROVER 出金审批员	静态互斥	直接拒绝	反洗钱双人控制
CRM_* 客户经理类	COMPLIANCE_REVIEWER 合规审查员	静态互斥	直接拒绝	利益冲突
ACCOUNT_OPENER 开户员	ACCOUNT_CLOSER 注销员	动态互斥	同会话拒绝	账户生命周期管控
GLOBAL_SYSADMIN 系统管理员	GLOBAL_AUDITOR 系统审计员	静态互斥	直接拒绝	管理与审计分离
RISK_MANAGER 风控建模	RISK_DIRECTOR 风控审批	静态互斥	触发审批豁免流程	模型开发与审批分离
TRADER 交易员	SETTLEMENT 清算员	静态互斥	直接拒绝	前中后台分离
IB_PARTNER 经纪人	CRM_STAFF 客户经理	静态互斥	直接拒绝	利益冲突

互斥类型说明：

- 静态互斥（Static SoD）：授权时拦截，用户永远不能同时持有两个角色。
- 动态互斥（Dynamic SoD）：用户可以同时持有两个角色，但同一会话不能同时激活。

4.6 数据权限分级

范围类型	代码	说明	典型适用角色
全集团	ALL	可查看集团下所有机构数据	集团总监、全局审计员
本机构及下级	ORG_TREE	可查看本机构及所有下级机构数据	分公司总经理

范围类型	代码	说明	典型适用角色
仅本机构	ORG_ONLY	仅本机构数据	营业部经理
本团队	TEAM	本团队所有数据	团队长
仅本人	SELF	仅自己负责/创建的数据	客户经理、普通柜员
自定义	CUSTOM	自定义机构 ID 列表或 SQL 条件	跨区域专员、特殊项目组

4.7 列级脱敏规则分级

字段	普通员工 (L1-L2)	主管 (L3-L4)	管理员 (L5+)	说明
手机号	138****8888	13812348888	明文	所有脱敏日志必须留痕
身份证号	310*****1234	310123*****	明文（需审批）	高敏感，明文访问审批
银行卡号	6228****8888	6228 1234 5678 ****	明文（需审批）	PCI-DSS 合规
客户资产	***万	123.4 万	明文	
住址	XX省XX市	XX省XX市XX区	明文	
邮箱	u***@example.com	user@example.com	明文	

五、核心对象模型（三层对象模型）

权限系统采用 **Subject（主体）** → **Grant（授权关系）** → **Permission（权限点）** 三层对象模型。

层级	对象	说明
第一层	Subject（主体）	用户、服务账号、应用等可被授权的实体
第二层	Grant（授权关系）	主体与角色的绑定关系，含范围、有效期、授权人等元数据
第三层	Permission（权限点）	角色所绑定的具体资源操作权限（含 ALLOW/DENY）

5.1 鉴权请求标准格式（PermissionCheckRequest）

```
JSON

{
  "requestId": "req_20250409_088001234_001",
  "entityId": 1001,
  "traceId": "tr_89757a8c9b_9921",
  "subject": {
    "userId": 88001234,
    "userType": "EMPLOYEE",
    "employeeNo": "E20210001",
    "orgId": 201,
    "deptId": 301,
    "activatedRoles": ["CRM_STAFF", "CRM_SENIOR"]
  },
  "resource": {
    "appCode": "CRM",
    "resourceCode": "crm:api:customer:export",
    "resourceType": "API",
    "httpMethod": "POST",
    "httpPath": "/api/crm/customers/export",
```

```
    "dataContext": {
      "customerId": 123456,
      "customerOrgId": 201,
      "customerLevel": "VIP",
      "amount": 5000000
    }
  },
  "action": "export",
  "environment": {
    "clientIp": "10.20.30.40",
    "deviceId": "dev_iphone_xyz",
    "deviceTrustScore": 85,
    "geoCountry": "CN",
    "geoCity": "Shanghai",
    "time": "2025-04-09T10:29:00+08:00",
    "weekday": 3,
    "mfaVerified": true
  }
}
```

subject 中的信息来自 Redis Session，网关在 Token 验证通过后填充。

5.2 鉴权决策结果（PermissionCheckResponse）

JSON

```
{
  "requestId": "req_20250409_088001234_001",
  "traceId": "tr_89757a8c9b_9921",
  "decision": "ALLOW",
  "decisionReason": "RBAC_ALLOW + ABAC_PASS",
  "hitPolicies": [
    "policy:rbac:role_resource:123",
    "policy:abac:crm.customer.org_scope_control:v3"
  ],
  "riskScore": 32,
  "riskFlags": [],
  "dataScope": {
    "type": "TEAM",
    "filterExpr": "team_id = 501"
  },
  "maskingRules": [
    { "field": "id_card", "rule": "HIDE_MIDDLE" },
    { "field": "mobile", "rule": "HIDE_MIDDLE_4" }
  ],
  "requireStepUp": false,
  "expiresAt": "2025-04-09T10:30:00+08:00",
  "latencyMs": 8,
  "degraded": false
}
```

决策结果枚举：

值	说明
ALLOW	允许访问
DENY	拒绝访问
DEGRADED_ALLOW	降级模式下放行（仅 RBAC 通过）

值	说明
STEP_UP_REQUIRED	需要二次验证（MFA）
RATE_LIMITED	被限频拒绝

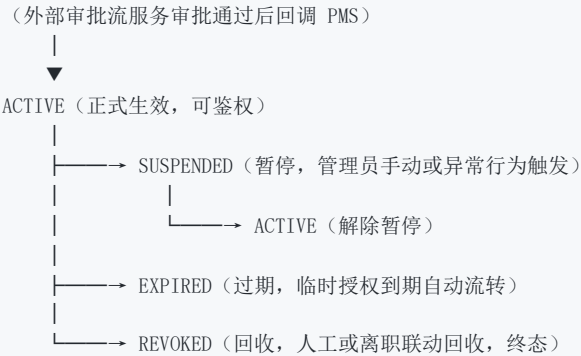
5.3 权限快照对象（PermissionSnapshot，缓存单元）

JSON

```
{
  "snapshotId": "snap_88001234_crm_v12",
  "userId": 88001234,
  "entityId": 1001,
  "appCode": "CRM",
  "version": 12,
  "builtAt": "2025-04-09T10:28:55Z",
  "ttlSeconds": 300,
  "activeRoles": [
    { "roleCode": "CRM_STAFF", "grantType": "FORMAL" },
    { "roleCode": "CRM_SENIOR", "grantType": "FORMAL" }
  ],
  "allowedResources": [
    "crm:menu:customer_list",
    "crm:api:customer:query",
    "crm:api:customer:update"
  ],
  "deniedResources": [
    "crm:api:customer:delete"
  ],
  "dataScopes": {
    "crm:data:customer": { "type": "TEAM", "teamId": 501 }
  },
  "maskingProfile": "L3_SENIOR"
}
```

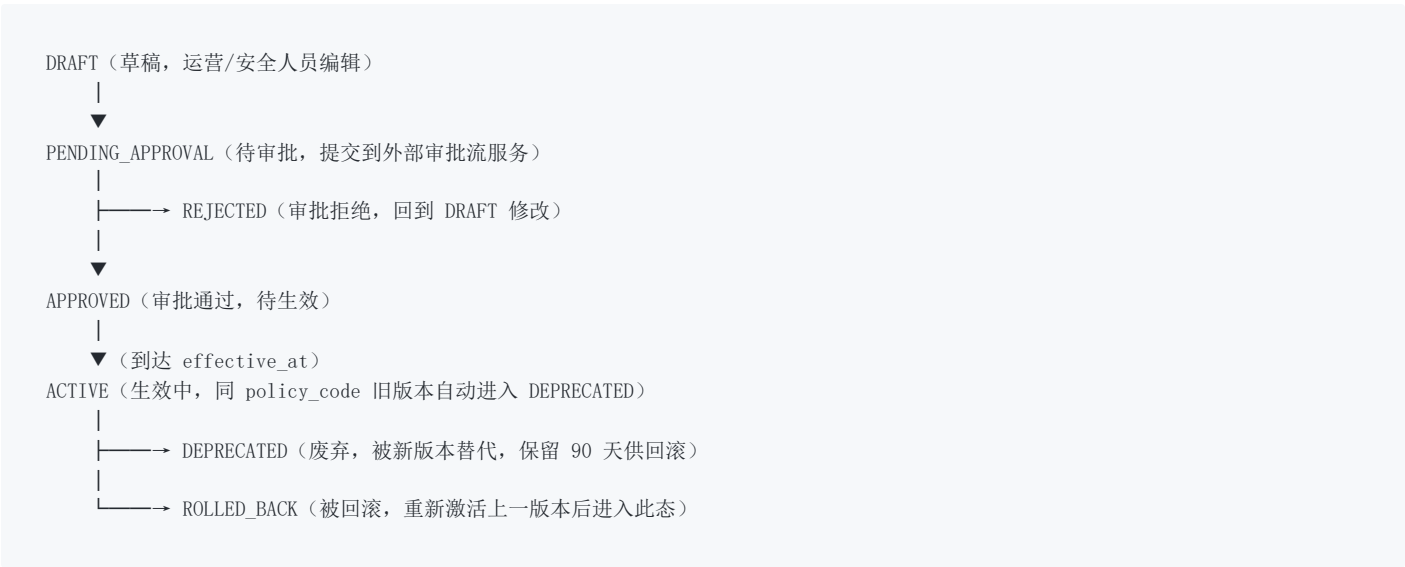
六、状态机

6.1 授权关系（User-Role Grant）状态机



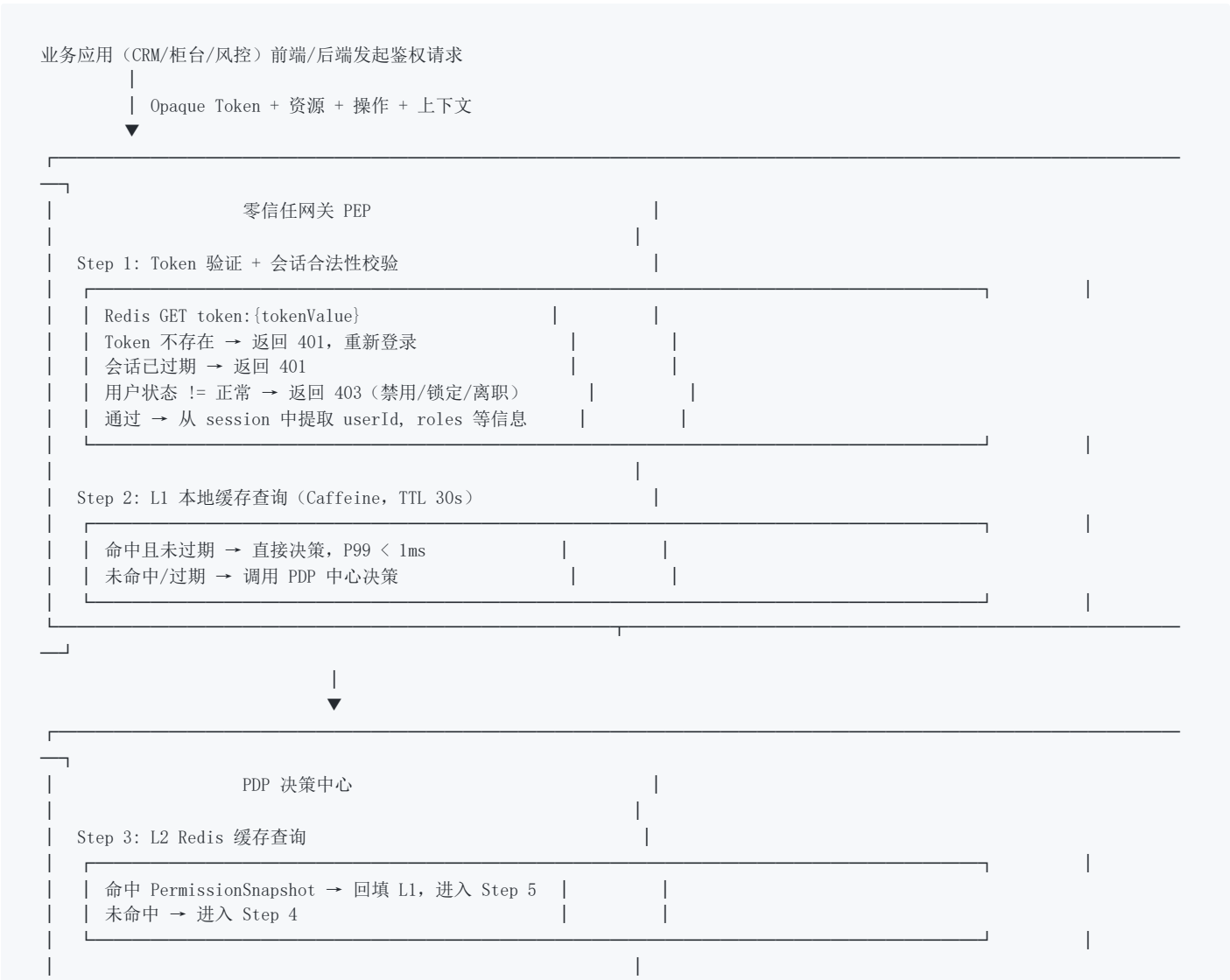
申请中（APPLYING）、待审批（PENDING_APPROVAL）、审批拒绝（REJECTED）等状态由外部审批流服务管理，PMS 仅在审批通过后创建 ACTIVE 状态的授权记录。

6.2 ABAC 策略版本状态机



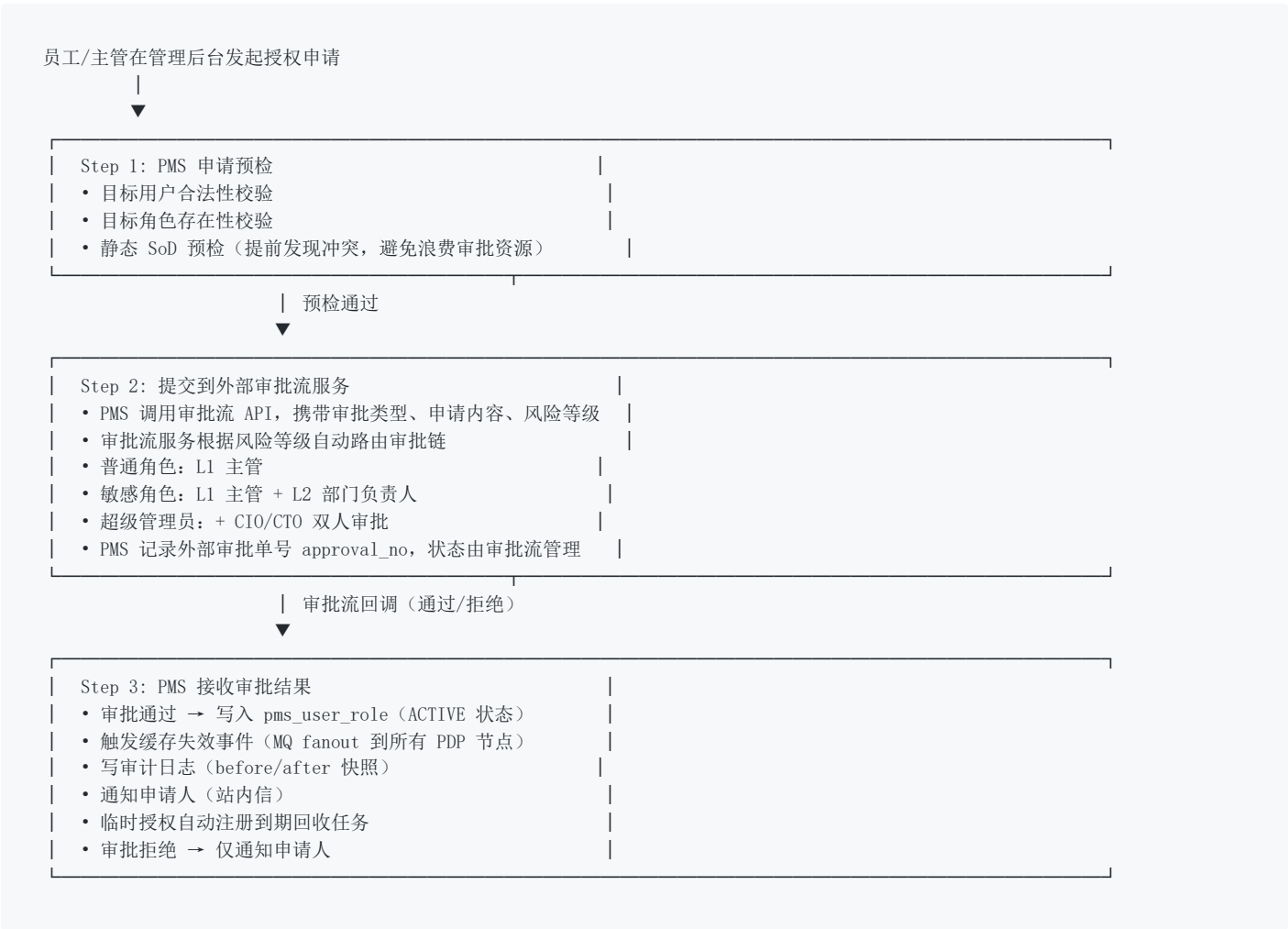
七、核心流程

7.1 鉴权完整生命周期

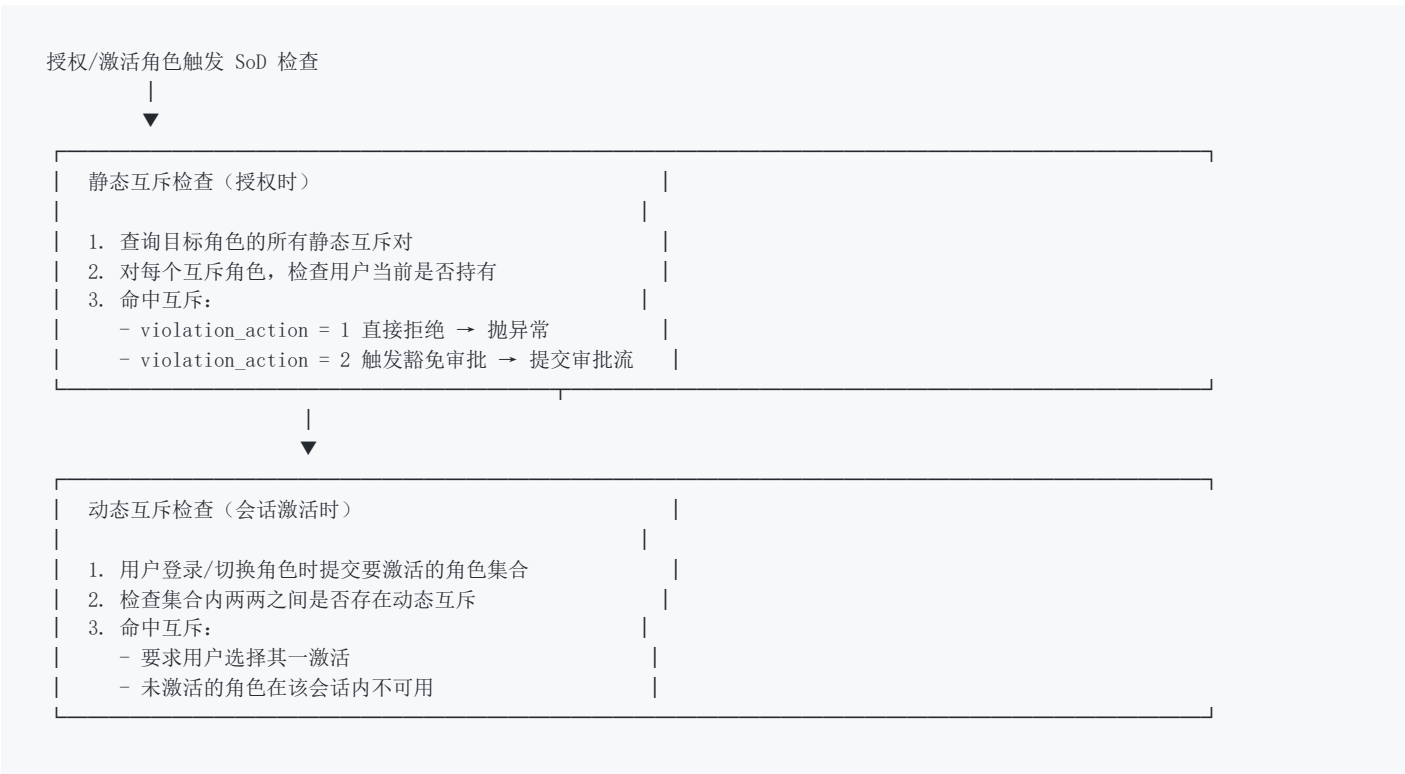




7.2 授权申请流程（PMS + 外部审批流服务协作）



7.3 SoD 互斥检查流程



7.4 策略热更新流程

运营/安全人员在管理后台修改 ABAC 策略



Step 1: 保存为 DRAFT 版本 (version +1)	
• 策略编辑器支持结构化表单	
• 实时语法校验 + 变量白名单校验	



Step 2: 策略测试 (灰度验证)	
• 输入测试上下文, 模拟执行	
• 支持批量回放历史请求, 对比新旧版本决策差异	



Step 3: 提交审批 (提交到外部审批流服务)	
• 生产策略变更必须双人审批	
• 审批通过 → APPROVED 状态	



Step 4: 定时生效	
• 设置 effective_at (支持凌晨低峰生效)	
• 调度器到达时间后:	
- 激活新版本 status=ACTIVE	
- 旧版本 status=DEPRECATED (保留 90 天)	
- MQ 广播策略变更事件	
- 所有 PDP 节点重载策略并清除相关缓存	



Step 5: 异常回滚	
• 任何时间可一键回滚到上一稳定版本	
• 回滚必须双人审批	
• 回滚事件强制记录审计	

7.5 离职联动与权限回收流程

HR 系统触发员工离职事件

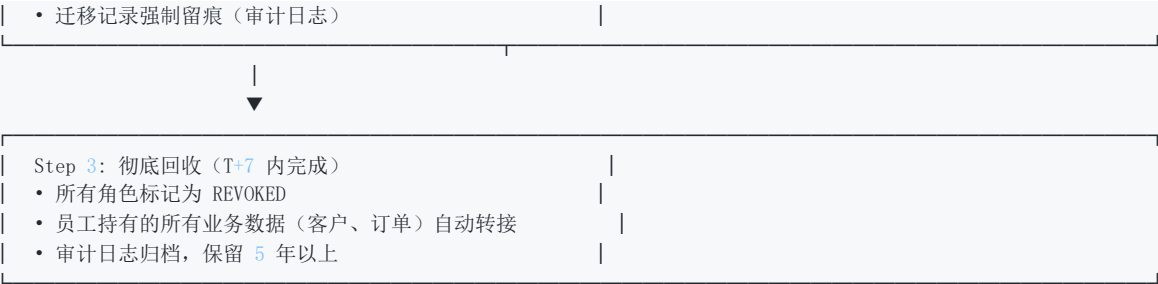


Outbox / CDC / 内部 API (事件类型 EMPLOYEE_OFFBOARD)

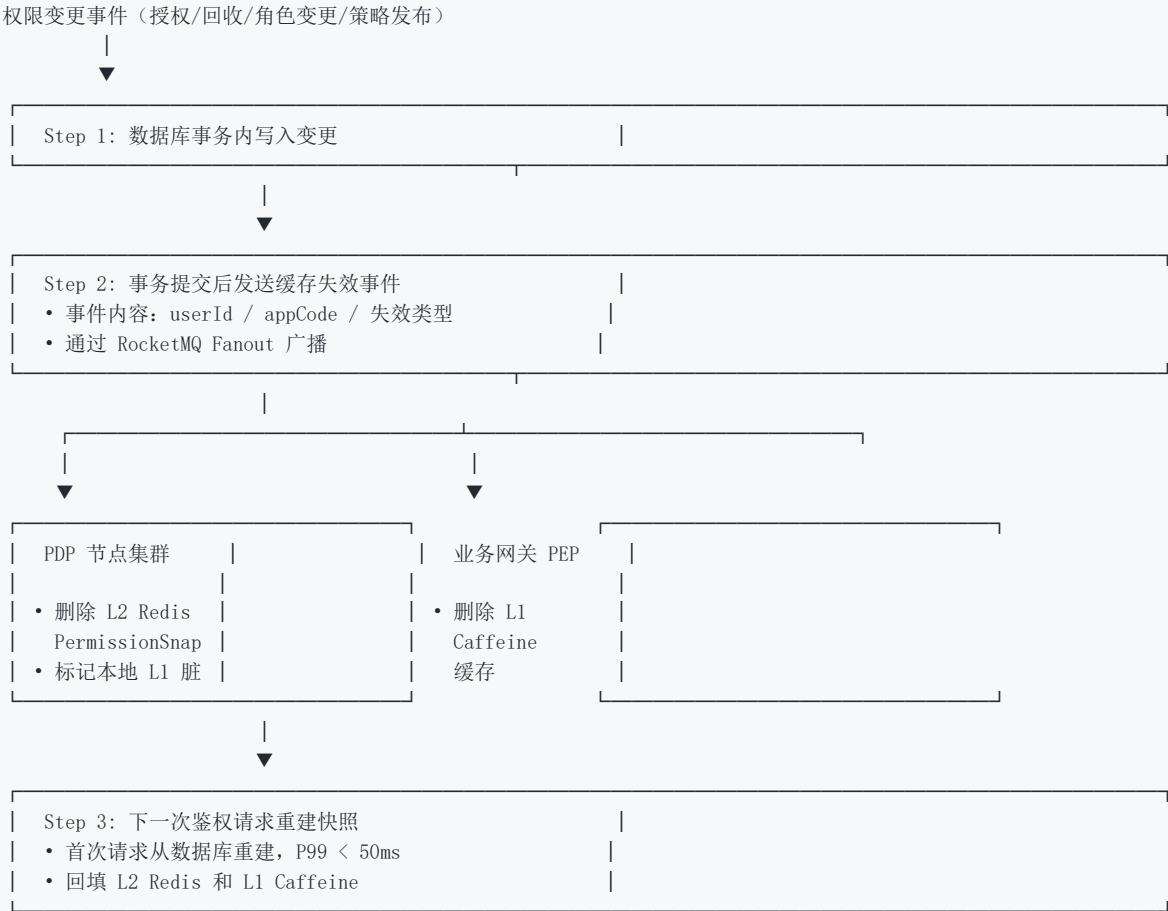
Step 1: 紧急冻结 (T+0 当日立即)	
• pms_user.status = 4 (离职冻结)	
• 强制踢出所有会话 (Redis DEL 该用户所有 token)	
• MQ 广播缓存失效事件	



Step 2: 权限接替 (T+1 内完成)	
• 触发“权限接替工单” (提交到审批流服务), 指派直属主管	
• 主管指定接替人员, 一键迁移角色	



7.6 缓存失效传播流程



八、数据库完整表结构（14 张表）

8.1 用户主表 pms_user

SQL

```
CREATE TABLE `pms_user` (  
  `id` BIGINT UNSIGNED NOT NULL AUTO_INCREMENT,  
  `entity_id` BIGINT UNSIGNED NOT NULL COMMENT '法律实体ID（多牌照隔离）',  
  `username` VARCHAR(64) NOT NULL COMMENT '登录账号',  
  `employee_no` VARCHAR(32) NULL COMMENT '员工工号，来自HR主数据',  
  `real_name` VARCHAR(64) NOT NULL,  
  `email` VARCHAR(128) NULL,
```

```

`mobile_encrypted`      VARCHAR(256)      NULL COMMENT '手机号密文（KMS加密）',
`mobile_mask`          VARCHAR(32)       NULL COMMENT '手机号脱敏展示',
`org_id`               BIGINT UNSIGNED NOT NULL COMMENT '所属机构',
`dept_id`              BIGINT UNSIGNED NOT NULL COMMENT '所属部门',
`team_id`              BIGINT UNSIGNED      NULL COMMENT '所属团队',
`position`             VARCHAR(64)         NULL COMMENT '职位',
`user_type`            TINYINT UNSIGNED NOT NULL DEFAULT 1 COMMENT '1:正式员工 2:外包 3:实习 4:服务账号 5:合作伙伴',
`security_level`       TINYINT UNSIGNED NOT NULL DEFAULT 1 COMMENT '安全等级 1-5，决定脱敏可见范围',
`status`              TINYINT UNSIGNED NOT NULL DEFAULT 1 COMMENT '1:正常 2:锁定 3:禁用 4:离职冻结',
`password_hash`        VARCHAR(256)       NULL COMMENT '密码哈希（bcrypt）',
`password_changed_at`  DATETIME          NULL,
`mfa_enabled`          TINYINT(1)         NOT NULL DEFAULT 0 COMMENT '是否启用MFA',
`mfa_secret_ref`       VARCHAR(256)       NULL COMMENT 'MFA密钥引用（配置中心路径）',
`last_login_at`        DATETIME(3)        NULL,
`last_login_ip`        VARCHAR(64)        NULL,
`created_at`           DATETIME          NOT NULL DEFAULT CURRENT_TIMESTAMP,
`updated_at`           DATETIME          NOT NULL DEFAULT CURRENT_TIMESTAMP ON UPDATE CURRENT_TIMESTAMP,
PRIMARY KEY (`id`),
UNIQUE KEY `uk_entity_username` (`entity_id`, `username`),
UNIQUE KEY `uk_entity_employee_no` (`entity_id`, `employee_no`),
KEY `idx_org_dept` (`entity_id`, `org_id`, `dept_id`),
KEY `idx_status` (`entity_id`, `status`)
) ENGINE=InnoDB DEFAULT CHARSET=utf8mb4 COLLATE=utf8mb4_unicode_ci
COMMENT='用户主表，身份源头，来自HR主数据同步';

```

8.2 接入应用表 pms_application

SQL

```

CREATE TABLE `pms_application` (
  `id` BIGINT UNSIGNED NOT NULL AUTO_INCREMENT,
  `entity_id` BIGINT UNSIGNED NOT NULL COMMENT '法律实体ID',
  `app_code` VARCHAR(64) NOT NULL COMMENT '应用唯一标识：CRM/COUNTER/RISK',
  `app_name` VARCHAR(128) NOT NULL,
  `domain` VARCHAR(32) NOT NULL COMMENT '业务域：
CRM/COUNTER/RISK/CLEARING/COMPLIANCE/IB/OPERATION/ADMIN',
  `app_type` TINYINT UNSIGNED NOT NULL COMMENT '1:核心交易 2:客户管理 3:风控合规 4:运营支撑',
  `client_id` VARCHAR(128) NULL COMMENT 'OAuth2 client_id（SSO接入用）',
  `client_secret_ref` VARCHAR(256) NULL COMMENT '密钥引用（配置中心路径，不存明文）',
  `callback_urls` JSON NULL COMMENT 'SSO回调白名单',
  `logout_url` VARCHAR(512) NULL,
  `token_ttl_seconds` INT UNSIGNED NOT NULL DEFAULT 3600 COMMENT 'Token有效期（Redis Session TTL）',
  `refresh_ttl_seconds` INT UNSIGNED NOT NULL DEFAULT 604800 COMMENT 'RefreshToken有效期',
  `require_mfa` TINYINT(1) NOT NULL DEFAULT 0 COMMENT '是否强制MFA',
  `ip_whitelist` VARCHAR(1024) NULL COMMENT 'IP白名单CIDR列表',
  `status` TINYINT UNSIGNED NOT NULL DEFAULT 1 COMMENT '1:启用 0:禁用',
  `owner` VARCHAR(64) NULL COMMENT '应用负责人',
  `created_at` DATETIME NOT NULL DEFAULT CURRENT_TIMESTAMP,
  `updated_at` DATETIME NOT NULL DEFAULT CURRENT_TIMESTAMP ON UPDATE CURRENT_TIMESTAMP,
  PRIMARY KEY (`id`),
  UNIQUE KEY `uk_entity_app_code` (`entity_id`, `app_code`),
  KEY `idx_domain` (`entity_id`, `domain`)
) ENGINE=InnoDB DEFAULT CHARSET=utf8mb4 COLLATE=utf8mb4_unicode_ci
COMMENT='接入应用注册表，统一管理各业务系统';

```

8.3 资源权限点表 pms_resource

SQL

```

CREATE TABLE `pms_resource` (
  `id` BIGINT UNSIGNED NOT NULL AUTO_INCREMENT,

```

```

`entity_id`                BIGINT UNSIGNED NOT NULL,
`app_id`                   BIGINT UNSIGNED NOT NULL,
`resource_code`            VARCHAR(128) NOT NULL COMMENT '全局唯一: crm:api:customer:export',
`resource_name`            VARCHAR(128) NOT NULL,
`resource_type`            VARCHAR(32) NOT NULL COMMENT 'MENU/BUTTON/API/DATA_OBJECT/FIELD/FUNCTION',
`parent_id`               BIGINT UNSIGNED NOT NULL DEFAULT 0,
`http_method`              VARCHAR(16) NULL COMMENT 'GET/POST/PUT/DELETE',
`http_path`                VARCHAR(256) NULL COMMENT 'API路径, 支持Ant风格通配',
`sensitivity`              TINYINT UNSIGNED NOT NULL DEFAULT 1 COMMENT '敏感等级: 1普通 2内部 3机密 4高度机密',
`require_mfa`              TINYINT(1) NOT NULL DEFAULT 0 COMMENT '执行时是否需要MFA复核',
`owner`                   VARCHAR(64) NULL COMMENT '资源负责人',
`status`                   TINYINT UNSIGNED NOT NULL DEFAULT 1,
`sort_order`               INT NOT NULL DEFAULT 0,
`created_at`               DATETIME NOT NULL DEFAULT CURRENT_TIMESTAMP,
`updated_at`               DATETIME NOT NULL DEFAULT CURRENT_TIMESTAMP ON UPDATE CURRENT_TIMESTAMP,
PRIMARY KEY (`id`),
UNIQUE KEY `uk_resource_code` (`entity_id`, `app_id`, `resource_code`),
KEY `idx_app_type` (`entity_id`, `app_id`, `resource_type`),
KEY `idx_parent` (`parent_id`)
) ENGINE=InnoDB DEFAULT CHARSET=utf8mb4 COLLATE=utf8mb4_unicode_ci
COMMENT='资源权限点定义, 菜单/按钮/API统一管理';

```

8.4 角色表 `pms_role`

SQL

```

CREATE TABLE `pms_role` (
  `id`                BIGINT UNSIGNED NOT NULL AUTO_INCREMENT,
  `entity_id`         BIGINT UNSIGNED NOT NULL,
  `app_id`            BIGINT UNSIGNED NULL COMMENT 'NULL=全局角色',
  `role_code`         VARCHAR(64) NOT NULL,
  `role_name`         VARCHAR(128) NOT NULL,
  `role_type`         TINYINT UNSIGNED NOT NULL COMMENT '1:全局 2:应用 3:业务 4:临时',
  `role_level`        TINYINT UNSIGNED NOT NULL DEFAULT 1 COMMENT '角色等级1-5, 决定审批链路',
  `parent_id`         BIGINT UNSIGNED NOT NULL DEFAULT 0,
  `inherit_depth`     TINYINT UNSIGNED NOT NULL DEFAULT 0 COMMENT '继承深度, 最大3',
  `deny_inherit`      TINYINT(1) NOT NULL DEFAULT 0 COMMENT 'DENY是否向下继承: 0不继承 1继承',
  `valid_from`        DATE NULL COMMENT '角色有效期开始',
  `valid_to`          DATE NULL COMMENT '角色有效期结束',
  `max_assignees`     INT NULL COMMENT '最大可授予人数, NULL=无限制',
  `status`            TINYINT UNSIGNED NOT NULL DEFAULT 1,
  `version`           INT NOT NULL DEFAULT 1 COMMENT '角色版本号, 权限变更递增',
  `description`       VARCHAR(512) NULL,
  `created_by`        BIGINT UNSIGNED NOT NULL,
  `created_at`        DATETIME NOT NULL DEFAULT CURRENT_TIMESTAMP,
  `updated_at`        DATETIME NOT NULL DEFAULT CURRENT_TIMESTAMP ON UPDATE CURRENT_TIMESTAMP,
  PRIMARY KEY (`id`),
  UNIQUE KEY `uk_role_code` (`entity_id`, `app_id`, `role_code`),
  KEY `idx_parent` (`parent_id`),
  KEY `idx_type_level` (`entity_id`, `role_type`, `role_level`)
) ENGINE=InnoDB DEFAULT CHARSET=utf8mb4 COLLATE=utf8mb4_unicode_ci
COMMENT='角色定义表';

```

8.5 角色继承闭包表 `pms_role_inheritance`

SQL

```

CREATE TABLE `pms_role_inheritance` (
  `entity_id`                BIGINT UNSIGNED NOT NULL,
  `ancestor_id`              BIGINT UNSIGNED NOT NULL COMMENT '祖先角色',
  `descendant_id`            BIGINT UNSIGNED NOT NULL COMMENT '后代角色',

```



```

`depth`                TINYINT UNSIGNED NOT NULL COMMENT '层级距离, 1=直接父子',
`created_at`            DATETIME          NOT NULL DEFAULT CURRENT_TIMESTAMP,
PRIMARY KEY (`entity_id`, `ancestor_id`, `descendant_id`),
KEY `idx_descendant`    (`entity_id`, `descendant_id`)
) ENGINE=InnoDB DEFAULT CHARSET=utf8mb4 COLLATE=utf8mb4_unicode_ci
COMMENT='角色继承闭包表, 预计算所有祖先-后代关系, 0(1)查询';

```

8.6 角色-资源关联表 `pms_role_resource`

SQL

```

CREATE TABLE `pms_role_resource` (
  `id`                BIGINT UNSIGNED NOT NULL AUTO_INCREMENT,
  `entity_id`         BIGINT UNSIGNED NOT NULL,
  `role_id`           BIGINT UNSIGNED NOT NULL,
  `resource_id`       BIGINT UNSIGNED NOT NULL,
  `effect`            VARCHAR(8)      NOT NULL DEFAULT 'ALLOW' COMMENT 'ALLOW/DENY',
  `created_by`        BIGINT UNSIGNED NOT NULL,
  `created_at`        DATETIME        NOT NULL DEFAULT CURRENT_TIMESTAMP,
  PRIMARY KEY (`id`),
  UNIQUE KEY `uk_role_resource_effect` (`entity_id`, `role_id`, `resource_id`, `effect`),
  KEY `idx_role`       (`entity_id`, `role_id`),
  KEY `idx_resource`   (`entity_id`, `resource_id`)
) ENGINE=InnoDB DEFAULT CHARSET=utf8mb4 COLLATE=utf8mb4_unicode_ci
COMMENT='角色权限点关联, 支持ALLOW/DENY双效果';

```

8.7 用户-角色授权表 `pms_user_role`

SQL

```

CREATE TABLE `pms_user_role` (
  `id`                BIGINT UNSIGNED NOT NULL AUTO_INCREMENT,
  `entity_id`         BIGINT UNSIGNED NOT NULL,
  `user_id`           BIGINT UNSIGNED NOT NULL,
  `role_id`           BIGINT UNSIGNED NOT NULL,
  `app_id`            BIGINT UNSIGNED NULL COMMENT 'NULL=所有应用',
  `org_scope_type`    VARCHAR(16)     NOT NULL DEFAULT 'ORG_ONLY' COMMENT 'ALL/ORG_TREE/ORG_ONLY/TEAM/SELF/CUSTOM',
  `org_scope_ids`     VARCHAR(1024)    NULL COMMENT '自定义机构列表 (CUSTOM时)',
  `grant_type`        VARCHAR(16)     NOT NULL DEFAULT 'FORMAL' COMMENT 'FORMAL/TEMPORARY/DELEGATED',
  `granted_by`        BIGINT UNSIGNED NOT NULL,
  `granted_at`        DATETIME         NOT NULL DEFAULT CURRENT_TIMESTAMP,
  `expire_at`         DATETIME         NULL COMMENT '过期时间, NULL=永久',
  `approval_no`       VARCHAR(64)      NULL COMMENT '外部审批流服务的审批单号',
  `reason`            VARCHAR(512)     NULL COMMENT '授权原因',
  `status`            VARCHAR(16)     NOT NULL DEFAULT 'ACTIVE' COMMENT 'ACTIVE/SUSPENDED/EXPIRED/REVOKED',
  `revoked_by`        BIGINT UNSIGNED NULL,
  `revoked_at`        DATETIME         NULL,
  `revoke_reason`     VARCHAR(512)     NULL,
  PRIMARY KEY (`id`),
  UNIQUE KEY `uk_user_role_app` (`entity_id`, `user_id`, `role_id`, `app_id`, `status`),
  KEY `idx_user_status` (`entity_id`, `user_id`, `status`),
  KEY `idx_expire_status` (`expire_at`, `status`),
  KEY `idx_role`       (`entity_id`, `role_id`, `status`)
) ENGINE=InnoDB DEFAULT CHARSET=utf8mb4 COLLATE=utf8mb4_unicode_ci
COMMENT='用户角色授权, 支持多维度范围+有效期+外部审批单关联';

```

8.8 SoD 互斥规则表 `pms_sod_rule`

SQL

```
CREATE TABLE `pms_sod_rule` (
  `id` BIGINT UNSIGNED NOT NULL AUTO_INCREMENT,
  `entity_id` BIGINT UNSIGNED NOT NULL,
  `rule_name` VARCHAR(128) NOT NULL,
  `rule_type` TINYINT UNSIGNED NOT NULL COMMENT '1:静态互斥 2:动态互斥',
  `role_id_a` BIGINT UNSIGNED NOT NULL,
  `role_id_b` BIGINT UNSIGNED NOT NULL,
  `conflict_scope` VARCHAR(64) NULL COMMENT '作用范围: app_code, NULL=全局',
  `compliance_ref` VARCHAR(256) NULL COMMENT '合规依据: SOX-3.2等',
  `violation_action` TINYINT UNSIGNED NOT NULL DEFAULT 1 COMMENT '1:直接拒绝 2:触发豁免审批',
  `exemption_approval` VARCHAR(32) NULL COMMENT '豁免审批等级: L1/L2/COMPLIANCE',
  `status` TINYINT UNSIGNED NOT NULL DEFAULT 1,
  `created_by` BIGINT UNSIGNED NOT NULL,
  `created_at` DATETIME NOT NULL DEFAULT CURRENT_TIMESTAMP,
  PRIMARY KEY (`id`),
  UNIQUE KEY `uk_role_pair` (`entity_id`, `role_id_a`, `role_id_b`, `conflict_scope`),
  KEY `idx_type` (`rule_type`, `status`)
) ENGINE=InnoDB DEFAULT CHARSET=utf8mb4 COLLATE=utf8mb4_unicode_ci
COMMENT='SoD职责分离规则表';
```

8.9 ABAC 策略表 pms_abac_policy

SQL

```
CREATE TABLE `pms_abac_policy` (
  `id` BIGINT UNSIGNED NOT NULL AUTO_INCREMENT,
  `entity_id` BIGINT UNSIGNED NOT NULL,
  `policy_code` VARCHAR(128) NOT NULL COMMENT '业务唯一标识',
  `policy_name` VARCHAR(128) NOT NULL,
  `policy_type` VARCHAR(32) NOT NULL COMMENT 'DATA_SCOPE/ENV_CONSTRAINT/BUSINESS_RULE/COMPLIANCE',
  `app_id` BIGINT UNSIGNED NOT NULL COMMENT 'NULL=全局策略',
  `resource_pattern` VARCHAR(256) NOT NULL COMMENT '资源匹配: crm:api:customer:*',
  `action_pattern` VARCHAR(128) NOT NULL COMMENT '操作匹配: read/write/*',
  `effect` VARCHAR(8) NOT NULL COMMENT 'ALLOW/DENY',
  `priority` SMALLINT NOT NULL DEFAULT 100 COMMENT 'DENY建议1-50, ALLOW建议51-200',
  `subject_conditions` JSON NULL COMMENT '主体条件: 角色/部门/职级',
  `resource_conditions` JSON NULL COMMENT '资源条件: 敏感等级/标签/归属',
  `environment_conditions` JSON NULL COMMENT '环境条件: 时间/IP/设备',
  `custom_function` VARCHAR(128) NULL COMMENT '扩展函数名(高级场景)',
  `version` INT NOT NULL DEFAULT 1,
  `prev_version_id` BIGINT UNSIGNED NOT NULL COMMENT '上一版本ID, 支持回滚',
  `status` VARCHAR(16) NOT NULL DEFAULT 'DRAFT' COMMENT 'DRAFT/PENDING/APPROVED/ACTIVE/DEPRECATED/ROLLED_BACK',
  `approved_by` BIGINT UNSIGNED NULL,
  `approved_at` DATETIME NULL,
  `effective_at` DATETIME NULL COMMENT '定时生效时间',
  `deprecated_at` DATETIME NULL,
  `created_by` BIGINT UNSIGNED NOT NULL,
  `created_at` DATETIME NOT NULL DEFAULT CURRENT_TIMESTAMP,
  `updated_at` DATETIME NOT NULL DEFAULT CURRENT_TIMESTAMP ON UPDATE CURRENT_TIMESTAMP,
  PRIMARY KEY (`id`),
  UNIQUE KEY `uk_policy_code_version` (`entity_id`, `policy_code`, `version`),
  KEY `idx_app_priority` (`entity_id`, `app_id`, `priority`, `status`),
  KEY `idx_effective` (`effective_at`, `status`),
  KEY `idx_status` (`entity_id`, `status`)
) ENGINE=InnoDB DEFAULT CHARSET=utf8mb4 COLLATE=utf8mb4_unicode_ci
COMMENT='ABAC动态策略, 结构化JSON存储+版本化+热更新';
```

8.10 数据范围表 pms_data_scope

SQL

```
CREATE TABLE `pms_data_scope` (
  `id` BIGINT UNSIGNED NOT NULL AUTO_INCREMENT,
  `entity_id` BIGINT UNSIGNED NOT NULL,
  `user_id` BIGINT UNSIGNED NULL COMMENT '针对用户的范围（NULL时走角色）',
  `role_id` BIGINT UNSIGNED NULL COMMENT '针对角色的默认范围',
  `app_id` BIGINT UNSIGNED NOT NULL,
  `resource_code` VARCHAR(128) NOT NULL COMMENT '数据对象: crm:data:customer',
  `scope_type` VARCHAR(16) NOT NULL COMMENT 'ALL/ORG_TREE/ORG_ONLY/TEAM/SELF/CUSTOM',
  `scope_config` JSON NULL COMMENT '自定义配置: {"orgIds":[1,2,3]} 或 {"customSql":"..."}',
  `valid_from` DATETIME NULL,
  `valid_to` DATETIME NULL,
  `granted_by` BIGINT UNSIGNED NOT NULL,
  `granted_at` DATETIME NOT NULL DEFAULT CURRENT_TIMESTAMP,
  PRIMARY KEY (`id`),
  KEY `idx_user_resource` (`entity_id`, `user_id`, `resource_code`),
  KEY `idx_role_resource` (`entity_id`, `role_id`, `resource_code`)
) ENGINE=InnoDB DEFAULT CHARSET=utf8mb4 COLLATE=utf8mb4_unicode_ci
COMMENT='行级数据范围表，支持用户级和角色级配置';
```

8.11 脱敏规则表 `pms_masking_rule`

SQL

```
CREATE TABLE `pms_masking_rule` (
  `id` BIGINT UNSIGNED NOT NULL AUTO_INCREMENT,
  `entity_id` BIGINT UNSIGNED NOT NULL,
  `resource_code` VARCHAR(128) NOT NULL COMMENT '数据对象',
  `field_name` VARCHAR(64) NOT NULL COMMENT '字段名',
  `field_sensitivity` TINYINT UNSIGNED NOT NULL COMMENT '字段敏感等级1-5',
  `min_security_level` TINYINT UNSIGNED NOT NULL COMMENT '所需最低安全等级才可见明文',
  `masking_strategy` VARCHAR(32) NOT NULL COMMENT '脱敏策略:
  HIDE_ALL/HIDE_MIDDLE/HIDE_MIDDLE_4/HIDE_PREFIX/HIDE_SUFFIX/HASH',
  `masking_char` VARCHAR(8) NOT NULL DEFAULT '*',
  `audit_plaintext_access` TINYINT(1) NOT NULL DEFAULT 1 COMMENT '明文访问是否强制审计',
  `status` TINYINT UNSIGNED NOT NULL DEFAULT 1,
  `created_at` DATETIME NOT NULL DEFAULT CURRENT_TIMESTAMP,
  `updated_at` DATETIME NOT NULL DEFAULT CURRENT_TIMESTAMP ON UPDATE CURRENT_TIMESTAMP,
  PRIMARY KEY (`id`),
  UNIQUE KEY `uk_resource_field` (`entity_id`, `resource_code`, `field_name`),
  KEY `idx_sensitivity` (`entity_id`, `field_sensitivity`)
) ENGINE=InnoDB DEFAULT CHARSET=utf8mb4 COLLATE=utf8mb4_unicode_ci
COMMENT='列级脱敏规则配置表';
```

8.12 审计日志主表 `pms_audit_log`

SQL

```
CREATE TABLE `pms_audit_log` (
  `id` BIGINT UNSIGNED NOT NULL AUTO_INCREMENT,
  `entity_id` BIGINT UNSIGNED NOT NULL,
  `trace_id` VARCHAR(64) NOT NULL,
  `log_type` VARCHAR(32) NOT NULL COMMENT 'AUTHN/AUTHZ/BIZ_OP/CONFIG_CHANGE/DATA_ACCESS',
  `user_id` BIGINT UNSIGNED NOT NULL,
  `username` VARCHAR(64) NOT NULL COMMENT '冗余存储，防用户删除后丢失',
  `app_id` BIGINT UNSIGNED NULL,
  `app_code` VARCHAR(64) NULL,
  `resource_code` VARCHAR(128) NULL,
  `action` VARCHAR(64) NOT NULL,
  `decision` VARCHAR(16) NOT NULL COMMENT 'ALLOW/DENY/DEGRADED_ALLOW/STEP_UP/RATE_LIMITED',
```

```

`deny_reason`          VARCHAR(256)          NULL,
`hit_policies`          VARCHAR(512)          NULL COMMENT '命中策略列表',
`client_ip`             VARCHAR(64)             NOT NULL,
`device_id`             VARCHAR(128)            NULL,
`user_agent`            VARCHAR(256)            NULL,
`geo_country`           VARCHAR(8)             NULL,
`geo_city`              VARCHAR(64)            NULL,
`risk_score`            TINYINT UNSIGNED      NULL,
`risk_flags`            VARCHAR(256)          NULL,
`latency_ms`            INT                     NULL,
`degraded`              TINYINT(1)           NOT NULL DEFAULT 0,
`log_hash`              VARCHAR(64)          NOT NULL COMMENT 'HMAC-SHA256签名',
`created_at`            DATETIME(3)          NOT NULL DEFAULT CURRENT_TIMESTAMP(3),
PRIMARY KEY (`id`, `created_at`),
KEY `idx_entity_user_time` (`entity_id`, `user_id`, `created_at`),
KEY `idx_entity_resource_time` (`entity_id`, `resource_code`, `created_at`),
KEY `idx_entity_decision_risk` (`entity_id`, `decision`, `risk_score`),
KEY `idx_trace`          (`trace_id`)
) ENGINE=InnoDB DEFAULT CHARSET=utf8mb4 COLLATE=utf8mb4_unicode_ci
COMMENT='权限审计主日志, 按月分区'
PARTITION BY RANGE (YEAR(created_at) * 100 + MONTH(created_at)) (
    PARTITION p_2026_01 VALUES LESS THAN (202602),
    PARTITION p_2026_02 VALUES LESS THAN (202603),
    PARTITION p_2026_03 VALUES LESS THAN (202604),
    PARTITION p_future VALUES LESS THAN MAXVALUE
);

```

8.13 审计日志详情表 `pms_audit_log_detail`

SQL

```

CREATE TABLE `pms_audit_log_detail` (
  `id`          BIGINT UNSIGNED NOT NULL AUTO_INCREMENT,
  `audit_log_id` BIGINT UNSIGNED NOT NULL,
  `entity_id`   BIGINT UNSIGNED NOT NULL,
  `before_snapshot` JSON          NULL COMMENT '变更前快照（配置变更/授权变更）',
  `after_snapshot` JSON          NULL,
  `diff_fields`  JSON          NULL COMMENT '变更字段列表',
  `request_payload` JSON        NULL COMMENT '请求载荷（脱敏）',
  `response_payload` JSON        NULL,
  `created_at`  DATETIME        NOT NULL DEFAULT CURRENT_TIMESTAMP,
  PRIMARY KEY (`id`),
  KEY `idx_audit_log` (`audit_log_id`)
) ENGINE=InnoDB DEFAULT CHARSET=utf8mb4 COLLATE=utf8mb4_unicode_ci
COMMENT='审计日志详情, 独立存储大JSON, 不影响主表写入性能';

```

8.14 合规配置表 `pms_compliance_config`

SQL

```

CREATE TABLE `pms_compliance_config` (
  `id`          BIGINT UNSIGNED NOT NULL AUTO_INCREMENT,
  `entity_id`   BIGINT UNSIGNED NOT NULL,
  `jurisdiction` VARCHAR(16)     NOT NULL DEFAULT 'CN' COMMENT '司法辖区: CN/HK/SG/US/EU',
  `config_key`  VARCHAR(128)     NOT NULL COMMENT 'LARGE_AMOUNT_THRESHOLD/WORK_HOURS/REVIEW_PERIOD 等',
  `config_value` VARCHAR(512)    NOT NULL,
  `value_type`  VARCHAR(16)     NOT NULL DEFAULT 'STRING' COMMENT 'STRING/NUMBER/JSON/BOOLEAN',
  `description` VARCHAR(512)     NULL,
  `last_modified_by` BIGINT UNSIGNED NOT NULL,
  `effective_at` DATETIME        NULL,
  `created_at`  DATETIME        NOT NULL DEFAULT CURRENT_TIMESTAMP,

```

```
`updated_at`          DATETIME          NOT NULL DEFAULT CURRENT_TIMESTAMP ON UPDATE CURRENT_TIMESTAMP,  
PRIMARY KEY (`id`),  
UNIQUE KEY `uk_jurisdiction_key` (`entity_id`, `jurisdiction`, `config_key`),  
KEY `idx_effective`    (`effective_at`)  
) ENGINE=InnoDB DEFAULT CHARSET=utf8mb4 COLLATE=utf8mb4_unicode_ci  
COMMENT='合规弹性配置，阈值类参数可配置，避免硬编码';
```

九、核心接口定义

9.1 鉴权与认证接口（PDP 核心）

9.1.1 权限校验（同步）

POST /internal/v1/pdp/check

业务网关/应用调用，要求 mTLS + 服务身份认证，P99 < 20ms。

Request Headers:

```
Content-Type: application/json  
X-Entity-Id: 1001  
X-Trace-Id: tr_abcl23  
Authorization: Bearer {service_token}
```

Request Body:

```
JSON  
  
{  
  "requestId": "req_20250409_088001234_001",  
  "subject": {  
    "userId": 88001234  
  },  
  "resource": {  
    "appCode": "CRM",  
    "resourceCode": "crm:api:customer:export",  
    "dataContext": { "customerId": 123456, "customerOrgId": 201 }  
  },  
  "action": "export",  
  "environment": {  
    "clientIp": "10.20.30.40",  
    "deviceId": "dev_xyz",  
    "time": "2025-04-09T10:29:00+08:00"  
  }  
}
```

subject 信息可简化为 userId，PDP 从 Redis Session 中补全其他信息。

Response（允许）:

```
JSON  
  
{  
  "code": 0,  
  "data": {  
    "decision": "ALLOW",  
    "decisionReason": "RBAC_ALLOW + ABAC_PASS",  
    "hitPolicies": ["policy:abac:crm.customer.org_scope_control:v3"],  
  }  
}
```

```
    "riskScore": 32,
    "dataScope": { "type": "TEAM", "filterExpr": "team_id = 501" },
    "maskingRules": [
      { "field": "id_card", "rule": "HIDE_MIDDLE" }
    ],
    "expiresAt": "2025-04-09T10:30:00+08:00",
    "latencyMs": 8
  }
}
```

Response (拒绝):

JSON

```
{
  "code": 0,
  "data": {
    "decision": "DENY",
    "decisionReason": "ABAC_DENY",
    "hitPolicies": ["policy:abac:crm.customer.cross_org_deny:v1"],
    "denyMessage": "您无权访问其他机构客户数据",
    "riskScore": 45
  }
}
```

9.1.2 批量权限预取

POST /internal/v1/pdp/batch-check

前端加载菜单时一次性返回所有菜单/按钮的可见性，避免逐个鉴权。

9.1.3 权限快照查询

GET /internal/v1/pdp/snapshot?userId={userId}&appCode={appCode}

管理后台用于展示用户权限概览。

9.2 SSO 认证接口

9.2.1 登录

POST /api/v1/auth/login

JSON

```
{
  "username": "zhangsan",
  "password": "...",
  "mfaCode": "123456",
  "deviceId": "dev_iphone_xyz",
  "clientIp": "10.20.30.40"
}
```

Response:

JSON

```
{
  "code": 0,
  "data": {
    "token": "opaque_token_abc123def456",
    "expiresIn": 28800,
  }
}
```

```
    "userInfo": {
      "userId": 88001234,
      "entityId": 1001,
      "username": "zhangsan",
      "realName": "张三",
      "orgId": 201,
      "deptId": 301,
      "activeRoles": ["CRM_STAFF", "CRM_SENIOR"],
      "mfaVerified": true
    }
  }
}
```

9.2.2 登出

POST /api/v1/auth/logout

删除 Redis 中的 Session，立即失效。

9.2.3 Token 刷新

POST /api/v1/auth/refresh

使用 Refresh Token 换取新的 Access Token，旧 Token 立即失效。

9.3 用户自服务接口

9.3.1 查询个人权限

GET /api/v1/me/permissions?appCode={appCode}

9.3.2 切换激活角色（动态互斥生效）

POST /api/v1/me/activate-roles

JSON

```
{
  "roleIds": [1001, 1002]
}
```

9.3.3 发起授权申请

POST /api/v1/me/access-requests

JSON

```
{
  "targetRoleId": 2001,
  "appId": 101,
  "orgScopeType": "TEAM",
  "durationHours": 168,
  "reason": "协助处理跨团队项目X"
}
```

PMS 收到后进行 SoD 预检，通过后提交到外部审批流服务，返回审批单号供用户跟踪。

9.4 管理后台接口

9.4.1 用户管理

- POST /admin/v1/users 创建用户（通常由HR同步，管理员仅管理服务账号）

- GET /admin/v1/users/{userId} 查询用户详情
- POST /admin/v1/users/{userId}/disable 禁用
- POST /admin/v1/users/{userId}/offboard 离职冻结
- POST /admin/v1/users/{userId}/kick 强制踢出所有会话（Redis DEL）

9.4.2 角色管理

- POST /admin/v1/roles 创建角色（需校验继承深度、SoD预检）
- POST /admin/v1/roles/{roleId}/resources 批量绑定权限点
- GET /admin/v1/roles/{roleId}/descendants 查询继承树
- POST /admin/v1/roles/{roleId}/clone 克隆角色

9.4.3 授权管理

- POST /admin/v1/grants 管理员直接授权（敏感角色仍需走外部审批流）
- DELETE /admin/v1/grants/{grantId} 回收授权

9.4.4 策略管理

- POST /admin/v1/policies 创建策略（DRAFT 状态）
- POST /admin/v1/policies/{id}/submit-approval 提交审批（提交到外部审批流服务）
- POST /admin/v1/policies/{id}/publish 发布（定时生效）
- POST /admin/v1/policies/{id}/rollback 回滚到上一版本
- POST /admin/v1/policies/test 策略测试（干跑）

9.4.5 SoD 管理

- POST /admin/v1/sod-rules 创建互斥规则
- GET /admin/v1/sod-rules/conflicts 全量冲突扫描报告

9.4.6 合规配置

- GET /admin/v1/compliance-configs 查询弹性合规参数
- PUT /admin/v1/compliance-configs/{key} 修改参数（需提交外部审批流）

9.4.7 僵尸权限治理

- GET /admin/v1/zombie-grants?unusedDays=90 查询僵尸权限列表
- POST /admin/v1/zombie-grants/batch-revoke 批量回收

僵尸权限治理由定时任务扫描 + 通知责任人确认，无需独立表。

9.5 外部联动接口

9.5.1 HR 入职事件接收

POST /internal/v1/events/hr/onboard

9.5.2 HR 离职事件接收

POST /internal/v1/events/hr/offboard

9.5.3 HR 转岗事件接收

POST /internal/v1/events/hr/transfer

9.5.4 审批流回调接口

POST /internal/v1/callbacks/approval

JSON

```
{
  "approvalNo": "APR_20250409_001",
  "approvalType": "ROLE_GRANT",
  "result": "APPROVED",
  "targetUserId": 88001234,
  "targetRoleId": 2001,
  "payload": { "orgScopeType": "TEAM", "durationHours": 168 },
}
```



```
"approvedBy": [100001, 100002],
"approvedAt": "2025-04-09T11:00:00+08:00"
}
```

PMS 收到审批通过回调后，执行实际授权（写入 pms_user_role）。

9.5.5 审计日志查询（供合规/监管使用）

POST /internal/v1/audit/query

JSON

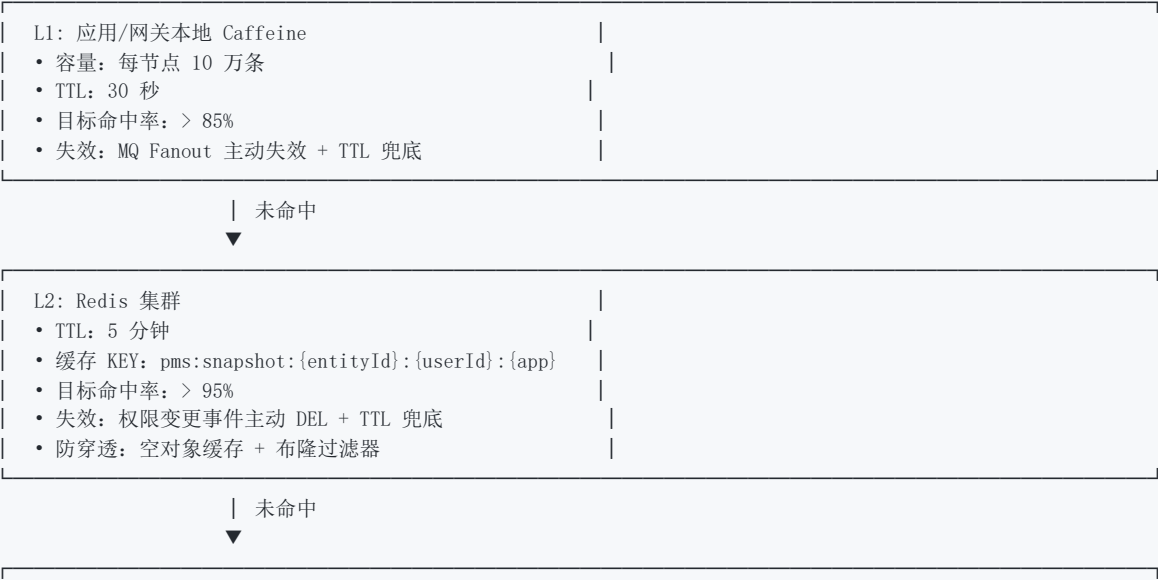
```
{
  "entityId": 1001,
  "userIdList": [88001234],
  "actionList": ["EXPORT", "DOWNLOAD"],
  "startTime": "2025-01-01T00:00:00Z",
  "endTime": "2025-04-01T00:00:00Z",
  "page": 1,
  "pageSize": 100
}
```

十、优先级、SLA 与缓存策略

10.1 鉴权请求分级 SLA

优先级	典型场景	延迟 SLA	降级策略	缓存策略
P0 关键	交易下单前鉴权、出金审批	P99 < 20ms	降级必拒绝	L1 本地缓存必命中
P1 重要	业务 API 鉴权、客户数据访问	P99 < 30ms	降级允许 RBAC	L1+L2 双级缓存
P2 普通	菜单/按钮可见性、报表查询	P99 < 50ms	降级允许	L2 Redis 缓存
P3 低优	管理后台操作、配置变更	P99 < 200ms	降级直通	直读 DB

10.2 缓存分层策略



L3: MySQL 权威数据源	
• 读写分离：写主库，读从库	
• 权限快照构建：单用户 < 50ms	
• 分库分表：按 entity_id 分库，用户表按 user_id 取模	

10.3 角色数量与继承限制

- 单个用户最多授予角色数：**20** 个
- 角色继承深度上限：**3** 层
- 单个角色最多权限点：**500** 个
- 权限快照大小上限：**64KB**（超过拆分多个快照）

十一、高并发与高可用关键机制

11.1 PDP 水平扩展

PDP 决策中心：

- 无状态设计，所有状态在 Redis / DB
- 按 CPU/内存自动扩容，单实例 QPS 承载 1-2 万
- 多可用区部署，单可用区故障自动切换

11.2 风险评分异步化

风险评分流程不阻塞主鉴权链路：

- 低延迟核心：RBAC + ABAC 决策路径必须 < 20ms
- 风险评分：并行执行，500ms 内完成
 - 若评分在主决策返回前完成：合并到响应
 - 若评分超时：主决策先返回，评分结果异步入审计库
- 高风险行为：通过 SIEM 实时告警，人工二次确认

11.3 缓存雪崩防护

防护措施：

- 随机 TTL：基础 TTL 5 分钟 + 随机 0-60 秒，避免集中失效
- 热点 key 预热：调度器每 4 分钟刷新 Top 1000 活跃用户快照
- 布隆过滤器：过滤不存在用户的穿透请求
- 限流熔断：L3 DB 单机 QPS > 2000 自动熔断走降级
- 单飞（SingleFlight）：同一 key 的并发重建仅 1 次查询 DB

11.4 审计日志高性能写入

写入路径：

- 同步写入 MQ（Kafka audit-log Topic）：RT < 5ms
- 消费者批量写入 MySQL（1000 条或 1 秒触发）
- 详情表异步写入，主表不等待
- ES 索引：Kafka → Logstash → ES，实时检索

吞吐指标：

- 峰值写入：10 万 TPS

- 查询延迟：ES 全文检索 P99 < 500ms
- 冷数据：OSS + WORM，按需查询

11.5 PDP 熔断与降级

- 熔断策略：
- 健康检查：每 10s 探测 PDP 响应时间和错误率
 - 连续 3 次错误率 > 5% → 触发降级模式一（L1 快照）
 - 连续 5 次错误率 > 20% → 触发降级模式二（保守白名单）
 - 降级期间每 30s 探测恢复，连续 3 次正常 → 恢复主模式
 - 降级状态同步：通过 Redis 广播到所有 PEP 节点

十二、中间件选型

组件	选型	用途	备注
主数据库	MySQL 8.0（主从+半同步）	权限主数据	按 entity_id 分库
缓存	Redis 7 Cluster	权限快照、会话管理、限频、幂等	6 主 6 从
搜索引擎	Elasticsearch 8	审计日志全文检索	冷热分层
冷存储	OSS/S3 + Object Lock	审计日志 WORM 归档	5-20 年
消息队列（事务型）	RocketMQ	权限变更事件	事务消息+顺序消息
消息队列（流式）	Kafka	审计日志、行为日志	高吞吐
API 网关	Kong/APISIX + 自研鉴权插件	PEP 策略执行点	插件化
SSO	自研（Opaque Token + Redis Session）	统一认证	支持 MFA
配置中心	Nacos / Apollo	凭据配置、业务参数	凭据加密存储
审批流引擎	Flowable/Camunda（独立服务）	通用审批 workflow	PMS 通过 API 对接
SIEM	Splunk/Elastic SIEM	安全分析与告警	实时关联分析
APM 追踪	SkyWalking / Jaeger	全链路追踪	TraceID 贯穿
监控告警	Prometheus + Grafana + AlertManager	指标采集与告警	-

十三、安全与合规设计

13.1 传输与存储安全

- 传输加密：全链路 TLS 1.3，服务间 mTLS 双向认证
- 存储加密：MySQL 透明加密（TDE）+ 列级加密（手机号、身份证）
- 凭据管理：数据库密码等凭据通过配置中心加密存储，不落明文
- 敏感信息脱敏：日志、审计、异常堆栈中自动识别并脱敏手机号/身份证/卡号
- 数据分级：L1 公开 / L2 内部 / L3 机密 / L4 高度机密 / L5 绝密

13.2 身份认证安全

- 密码策略：12 位以上、复杂度要求、90 天强制修改、历史 5 次不可重用

- **MFA 强制**：所有敏感操作、高风险设备必须 MFA（TOTP/FIDO2）
- **异常登录检测**：异地/异设备/异时间 → 强制 Step-Up 认证
- **会话管理**：Redis Session，8 小时无操作自动过期、风险评分过高强制重新认证、支持即时踢人
- **暴力破解防护**：连续 5 次失败锁定 30 分钟，告警通知用户

13.3 合规留痕矩阵

留痕内容	保留期限	存储介质	合规依据
登录/登出日志	5 年	MySQL + ES + OSS	等保 2.0
权限决策日志	5 年	MySQL + ES + OSS（高危 WORM）	SOX
授权变更日志	10 年	MySQL + OSS WORM	SOX
策略变更日志	10 年	MySQL + OSS WORM	内控要求
数据访问日志（明文）	5 年	MySQL + ES	个人信息保护法

13.4 多司法辖区差异化

辖区	关键要求	本设计适配
CN	等保 2.0、个保法	内网边界防护 + 数据不出境 + 数据本地化
HK	SFC、PDPO	客户数据本地存储 + 同意管理
SG	MAS TRM、PDPA	加密+审计+数据主权
US	SOX、PCI-DSS	四眼原则+审计+PCI
EU	GDPR、MiFID II	数据主权+被遗忘权+跨境传输同意

十四、监控指标与告警规范

监控指标	告警阈值	告警级别	处理预案
PDP 决策延迟 P99	> 50ms	P0（电话告警值班）	检查 Redis 集群 / DB 负载
PDP 决策错误率	> 1%	P0	可能触发降级，立即排查
PDP 降级模式切换	任意触发	P0	立即人工确认，排查根因
L2 Redis 命中率	< 90%	P1	排查冷启动或缓存击穿
审计日志写入失败	任意失败	P0	本地缓存暂存，恢复后补写
SoD 违规攻击尝试	短时 > 10 次	P1	疑似恶意操作，人工介入
高风险决策频次	> 基线 200%	P1	可能异常行为
会话异常踢出	短时集中	P1	可能批量被攻击
HR 离职联动延迟	> 1 小时	P1	可能有账号未冻结
僵尸权限占比	> 10%	P2	触发清理任务
异地登录告警	实时	P2	用户自助确认或 Step-Up

十五、实施路线图（务实分期）

Phase 1（第1-2月）：立刻能用 - 基础身份与RBAC

目标：解决账号孤岛 + 基础可追溯

交付物：

- HR 主数据对接，统一用户目录
- SSO 单点登录（Opaque Token + Redis Session）
- 基础 RBAC（角色-权限绑定，覆盖 80% 日常场景）
- 角色继承（闭包表）
- L2 Redis 权限缓存
- 基础审计日志（登录 + 权限决策 + HMAC签名）
- 离职联动（HR 事件驱动，当日冻结）

不包含：ABAC、风险评分、数据脱敏、SoD

成功标准：

- ✓ 所有系统统一账号登录
- ✓ 离职账号 24 小时内自动冻结
- ✓ 权限变更有记录

Phase 2（第3-4月）：精细化控制 - 数据权限与SoD

目标：数据权限落地 + 合规底线

交付物：

- 行级数据权限（机构隔离、团队隔离）
- 列级脱敏（手机号、身份证、资产信息）
- SoD 静态+动态互斥规则（系统强制）
- L1 本地缓存 + 三级降级
- 审计日志 WORM 冷存储

成功标准：

- ✓ 客户经理只能看分配的客户
- ✓ 跨机构数据物理隔离
- ✓ 交易四眼原则 100% 强制

Phase 3（第5-6月）：动态策略 - ABAC与风险评分

目标：动态场景覆盖

交付物：

- ABAC 策略引擎（结构化 JSON）
- 策略管理后台（配置化、版本化、热更新）
- 基础风险评分（设备+时间+地理）
- Step-Up 认证（异常场景升级 MFA）
- 合规弹性配置

成功标准：

- ✓ 非工作时间限制高危操作
- ✓ 异地登录触发二次验证

Phase 4（第7-8月）：通用审批流服务

目标：PMS 权限变更审批 + 其他业务审批统一

交付物：

- 独立通用审批流服务（基于 Flowable/Camunda）
- PMS 对接审批流：授权申请、策略变更、SoD 豁免、合规配置变更
- 审批链路由（根据风险等级自动决定审批链）
- 其他业务系统（报销、合同等）可复用

成功标准：

- ✓ 敏感权限变更 100% 走审批
- ✓ 审批流服务可被 3 个以上系统复用

Phase 5（第9月+）：智能化 - UEBA与持续优化

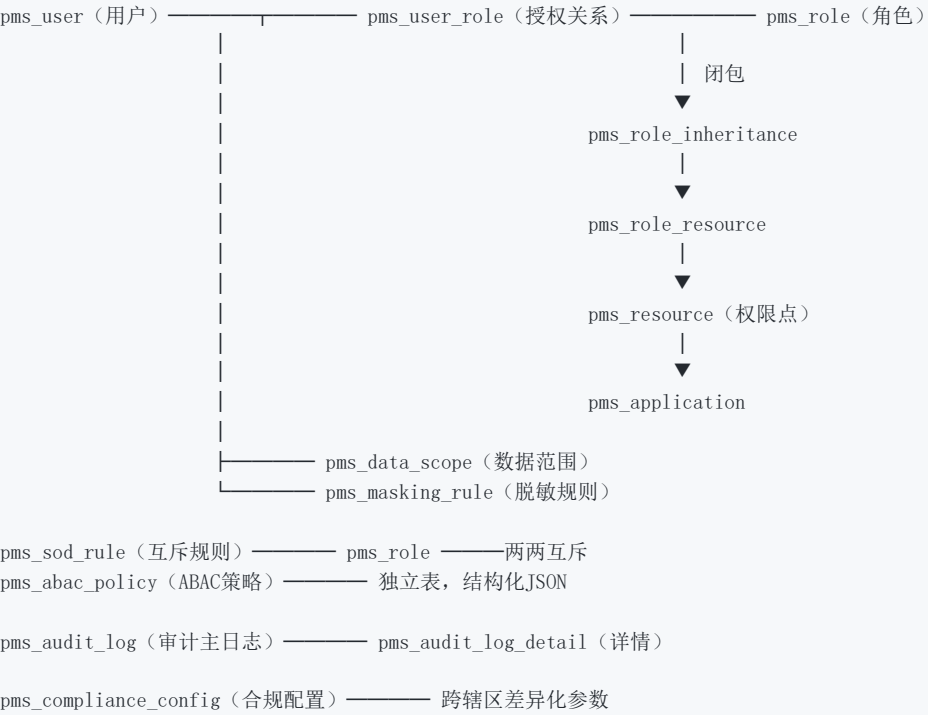
目标：降本增效

交付物：

- UEBA 异常行为检测（AI 辅助）
- 智能权限推荐（基于岗位历史）
- 僵尸权限自动化治理
- 多法律实体与多辖区支持完善
- 持续优化与运营

注意：Phase 5 锦上添花，前 4 个 Phase 才是立身之本

十六、ER 关系概览



- 【外部系统】
- Redis：会话管理（token → session）+ 权限快照缓存
 - 审批流服务：权限变更审批（PMS 通过 approval_no 关联）
 - 配置中心：凭据托管（数据库密码、API Key 等）

十七、核心架构决策总结

决策点	本方案选择	理由
认证方案	Opaque Token + Redis Session	即时踢人/冻结，无 JWT 失效延迟问题，架构更简单
会话存储	Redis（不落 MySQL）	高性能、即时失效，审计日志覆盖追溯需求
权限模型	RBAC + ABAC + PBAC 三层融合	NIST 标准 + 动态策略双重需求
角色继承	闭包表，最大 3 层	O(1) 查询，避免递归；超过 3 层复杂度爆炸
DENY 策略	默认不继承；全局 DENY 显式标记继承	避免意外权限剥夺
策略存储	结构化 JSON + 字段 schema 约束	可查询、可验证、可索引、可测试

决策点	本方案选择	理由
策略更新	版本化 + 审批 + 定时生效 + 一键回滚	生产策略变更高风险
审批工作流	独立通用审批流服务	审批是通用能力，不应耦合在权限系统中
凭据管理	配置中心加密存储	够用、简单，无需 Vault 级别复杂度
审计写入	异步批量 + 主详表分离 + HMAC	不影响 RT + 防篡改
缓存策略	L1 Caffeine + L2 Redis + L3 DB 三级 + 主动失效	鉴权是热路径
降级策略	三级降级 + 高危降级必拒绝	PMS 故障时业务不失控
多法律实体	entity_id 贯穿全表	多牌照合规举证清晰
SoD 实施	静态+动态双重互斥 + 豁免审批流	四眼原则刚需
僵尸权限治理	定时任务扫描 + 通知，无独立表	轻量实现，避免过度设计
实施节奏	2 个月出 Phase 1，分 5 期迭代	业务等不起，避免烂尾